Workshop — Microsoft Defender for Identity

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Workshop: Microsoft Defender for Identity 4

What you get . . . 4

What this delivers . . . 4

The standard deployment model . . . 4

Boundary . . . 5

Effort . . . 5

1. Solution Overview — Workshop: Microsoft Defender for Identity 5

What this workshop is . . . 5

What Microsoft Defender for Identity is (the concept) . . . 5

How the operator uses it (the console and workflows) . . . 6

The standard deployment model (how the workshop is run) . . . 6

The five labs (scope of the hands-on) . . . 6

What is in scope . . . 7

What is out of scope (and where it lives) . . . 7

Connections and authentication used . . . 7

2. Requirements — Workshop: Microsoft Defender for Identity 7

R1. Defender for Identity deployed with at least one healthy sensor . . . 7

R2. A pilot/lab scope for the labs . . . 8

R3. ISPM assessment data populated . . . 8

R4. A candidate account for the honeytoken lab . . . 8

R5. Advanced hunting access (identity tables) . . . 8

R6. Read-only Graph app or delegated permissions for the lab helpers . . . 8

R7. Facilitator with the right role, attendees with reader access . . . 9

Global Requirements — Defender (category-level) 9

G1. Microsoft 365 / Entra tenant . . . 9

G2. Defender licensing . . . 9

G3. Administrative roles (least privilege) . . . 9

G4. Onboarding reach to endpoints / identity / workloads . . . 10

G5. Network access to Defender service endpoints . . . 10

G6. A pilot ring . . . 10

G7. Log Analytics workspace (where required) . . . 10

G8. Response governance . . . 10

3. Implementation — Workshop Runbook: Microsoft Defender for Identity 10

Lab 0 — Readiness check (Assess) . . . 11

Lab 1 — Identity attack paths & the entity page (Configure/learn) . . . 11

Lab 2 — Recon & lateral-movement detections (Pilot) . . . 12
Lab 3 — Honeytokens (Pilot, one facilitator config action) . . . 12
Lab 4 — ISPM posture (Validate posture, no enforcement) . . . 13
Lab 5 — Investigation end-to-end + response rehearsal (Validate/Expand) . . . 13
Wrap-up (Expand) . . . 13
5. Testing & Knowledge-Check — Workshop: Microsoft Defender for Identity 14
Part A — Environment / lab validation (scripts) . . . 14
Part B — Knowledge-check (per attendee) . . . 14
Part C — Live demonstration (capstone) . . . 15
6. Troubleshooting — Workshop: Microsoft Defender for Identity 15
Sensor shows Unhealthy or no sensors listed . . . 15
Entity pages / advanced hunting return no identity data . . . 16
ISPM recommendations are empty (Lab 4) . . . 16
`Connect-MgGraph` fails or scopes are not granted . . . 16
`Get-MgSecurityAlertV2` returns nothing . . . 16
`signInActivity` is blank (honeytoken candidate list empty) . . . 16
Honeytoken detection did not fire in the demo . . . 16
Response actions greyed out (Lab 5) . . . 17
Portal menu paths don't match . . . 17
7. Best Practices & Where to Go Next — Workshop: Microsoft Defender for Identity 17
Running the workshop well . . . 17
Operating MDI well (the habits to instill) . . . 17
Common anti-patterns to avoid . . . 18
Where to go next (adjacent catalog areas) . . . 18
8. Deliverables Summary — Workshop: Microsoft Defender for Identity 18
Documentation (source/) . . . 19
Lab-helper assets (scripts/) . . . 19
Take-home runbook artifacts (produced during the labs) . . . 19
Appendix A — PowerShell Scripts 21

Executive Summary — Workshop: Microsoft Defender for Identity

White-label · Defender · Enablement / Training deliverable

A licensed tool only pays off when the team can drive it. Many organizations turn on **Microsoft Defender for Identity (MDI)**, then leave it half-used because no one on the team is confident with the console, the detections, or the investigation workflow. This is a **structured enablement workshop** that takes your admins and SOC analysts from "we have it" to "we operate it" — through concepts, **guided hands-on labs**, a **take-home runbook**, and a **knowledge-check**.

This is a training deliverable, not a deployment project. It assumes MDI sensors are (or are being) onboarded — the *how-to-onboard* work lives in the catalog's Defender XDR onboarding solution — and focuses on the **operating skills**: reading identity attack paths, recognizing lateral-movement and reconnaissance detections, deploying and monitoring **honeytokens**, working the **Identity Security Posture Management (ISPM)** recommendations, and running a clean investigation. Every lab is **read-only or preview-first**, so a team can learn safely in a pilot without disrupting the tenant.

What you get

- A plain-language **Solution Overview** of Defender for Identity — what it is, how the sensors and the identity threat detections work, and the console/workflows an operator uses daily.
- A **Requirements Guide** covering the workshop-specific prerequisites (a lab environment, sensor health, ISPM data) with verify / implement-if-missing for each.
- An **Implementation Guide** that is the **facilitator + student runbook** — five guided labs, each with named objects, exact portal navigation, and explicit pass/fail checks.
- Five **lab-helper assets**: read-only PowerShell discovery/validation/report scripts (Microsoft Graph Security) plus a **KQL query pack** for advanced hunting across the identity tables.
- A **Testing / knowledge-check** guide and a **Troubleshooting** guide so the workshop runs smoothly and the team can self-assess.
- A **Best-Practices + where-to-go-next** guide that points to the adjacent catalog areas (XDR onboarding, threat hunting, SOC operations).

What this delivers

A team that can **confidently operate Microsoft Defender for Identity**: they understand identity attack paths and the recon/lateral-movement detection families, they have deployed and verified a honeytoken, they can read and act on ISPM recommendations, and they can run an identity investigation end to end — with a **runbook they keep** and reuse. The measurable outcome is competence: every attendee completes the labs and passes the knowledge-check.

The standard deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — the workshop is delivered against a **pilot** scope (a lab or a small pilot ring), attendees validate each skill with a pass/fail gate, and the team then expands

the practices to the full environment.

Boundary

This workshop delivers the **technical enablement and the operating runbook**. It does **not** make incident-response, regulatory, or records determinations — those belong to the customer's SOC, security, and compliance functions. Response actions (disable a user, force password reset) are taught in an **approval-gated, simulate-first** posture. Some MDI capabilities are **license-** or **preview-gated**; those facts are flagged **verify current availability in your tenant**.

Effort

A competent facilitator can run the full workshop in a focused one- to two-day engagement against a pilot; the labs and runbook are then reusable to onboard new analysts. No production change is required to complete the workshop — the labs are read-only or preview-first.

1. Solution Overview — Workshop: Microsoft Defender for Identity

What this workshop is

This is an **enablement / training** deliverable, not a deployment project. It teaches your admins and SOC analysts to **operate Microsoft Defender for Identity (MDI)** confidently — through concept sessions, **five guided hands-on labs**, a **take-home runbook**, and a **knowledge-check**. The output is a skilled team and a reusable runbook, not a new tenant configuration. The labs are designed to be run in a **pilot or lab environment** and are **read-only or preview-first**, so learning never disrupts production.

What Microsoft Defender for Identity is (the concept)

Microsoft Defender for Identity is the **identity-threat detection and response** pillar of Microsoft Defender XDR. Lightweight **sensors** installed on **domain controllers**, **AD CS**, and **AD FS / Entra Connect** servers watch authentication and directory traffic and behavior, and send signal to the cloud service. MDI then:

- **Detects identity attacks** across the kill chain — **reconnaissance** (account/SPN/network enumeration), **compromised-credential** attempts (brute force, password spray), **lateral movement** (Pass-the-Hash, Pass-the-Ticket, overpass-the-hash), and **domain-dominance** techniques (DCSync, DCShadow, Golden Ticket, skeleton key).
- **Surfaces identity posture** through **Identity Security Posture Management (ISPM)** assessments — misconfigurations and risky practices (unconstrained delegation, legacy protocols, exposed credentials, dormant privileged accounts) with prioritized recommendations.
- **Lets you plant honeytokens** — deliberately un-used decoy accounts that should *never* authenticate; any activity on them is high-fidelity evidence of an intruder.
- **Feeds Defender XDR** — MDI alerts and identity signals correlate into unified **incidents**, enrich the **user/device entity pages**, and are queryable in **advanced hunting** (the `Identity*` tables).

The operator's job is to **read** those detections and posture recommendations, **investigate** them using the entity timelines, and **respond** through the approved workflow. That operating skill is what this workshop builds.

How the operator uses it (the console and workflows)

1. **The unified portal** — `https://security.microsoft.com`. MDI alerts appear inside **Incidents & alerts**; identity settings live under **Settings** → **Identities**; posture lives under **Secure Score / Exposure management** → **ISPM recommendations**.

2. **Entity pages** — a **user** or **device** page shows the timeline, related alerts, lateral-movement paths, and investigation priority. This is the analyst's primary investigation surface.

3. **Advanced hunting** — the `IdentityLogonEvents`, `IdentityQueryEvents`, `IdentityDirectoryEvents`, and `IdentityInfo` tables let analysts hunt across identity telemetry with KQL.

4. **Honeytokens** — configured under **Settings** → **Identities** → **Entity tags** → **Honeytoken**; monitored via a dedicated detection and a saved hunting query.

5. **Response** — from an alert/entity, an analyst can **disable a user**, **force password reset**, or **suspend** (subject to the organization's approval gate); MDI also feeds automatic attack-disruption in XDR.

The standard deployment model (how the workshop is run)

This workshop follows the same repeatable model as every catalog solution:

• **Assess** — confirm the lab/pilot scope, sensor health, licensing, and that ISPM data has populated (Lab 0 readiness check).

• **Configure** — set up the workshop objects: the honeytoken account, the saved hunting queries, and the facilitator/attendee roles.

• **Pilot** — run the five labs against the pilot scope; every attendee performs the steps.

• **Validate** — each lab has a **pass/fail gate** and the workshop ends with a **knowledge-check**.

• **Expand** — the team applies the runbook and practices to the full environment and onboards new analysts with it.

The five labs (scope of the hands-on)

• **Lab 1 — Identity attack paths & the entity page.** Read a user/device entity page; interpret investigation priority and lateral-movement paths.

• **Lab 2 — Recon & lateral-movement detections.** Recognize the detection families; map them to MITRE ATT&CK; triage a simulated recon/lateral-movement alert.

• **Lab 3 — Honeytokens.** Choose, tag, and verify a honeytoken account; understand and monitor the honeytoken detection.

• **Lab 4 — ISPM posture.** Read the ISPM recommendations, prioritize them, and produce a remediation shortlist (no enforcement).

• **Lab 5 — Investigation end-to-end.** Run a full identity investigation using the entity timeline and advanced hunting; document findings; rehearse the **approval-gated** response.

What is in scope

• Concept enablement, five guided labs, the take-home runbook, and the knowledge-check for **operating** MDI.

• Read-only discovery/validation/reporting helpers and a KQL hunting pack for the labs.

What is out of scope (and where it lives)

• **Onboarding MDI sensors** and standing up Defender XDR — see the catalog's **Defender XDR Deployment / Unified Onboarding** solution.

• **Broad multi-pillar threat hunting** and SOC process design — see the **Threat Hunting** and **SOC / XDR operations** solutions.

• **Incident-response, regulatory, and records decisions** — these are the customer's SOC/security/compliance functions' determinations; the workshop teaches the technical workflow only.

• **Endpoint, email, and cloud-app detections** — covered by the sibling Defender workshops (Endpoint, Office 365, Cloud Apps).

Connections and authentication used

• The **Microsoft Defender portal** (`https://security.microsoft.com`) for alerts, incidents, entity pages, Identity settings, ISPM, and advanced hunting.

• **Microsoft Graph Security / Graph** (via the lab PowerShell helpers, delegated **read** scopes such as `SecurityEvents.Read.All`, `SecurityAlert.Read.All`, `IdentityRiskEvent.Read.All`) for read-only discovery, validation, and reporting. *Confirm exact scopes and availability in your tenant.*

• No lab writes to production; response actions are **simulated / approval-gated**.

2. Requirements — Workshop: Microsoft Defender for Identity

The **category-level prerequisites** (tenant, Defender licensing, admin roles, onboarding reach, network access, pilot ring, Log Analytics, response governance) are covered once in `global-requirements-defender.md` — read that first. This section lists only the **workshop-specific** prerequisites. Each item: **Description / Why required / How to verify / How to implement if missing.**

R1. Defender for Identity deployed with at least one healthy sensor

Description: MDI is active in the tenant and at least one sensor (on a domain controller / AD CS / AD FS) is reporting **Healthy**. **Why required:** The labs read real identity telemetry, alerts, and entity timelines. Without a reporting sensor there is nothing to investigate and the entity pages/hunting tables are empty. **How to verify:** In `https://security.microsoft.com` go to **Settings** → **Identities** → **Sensors**; confirm at least one sensor with health status **Healthy** and recent activity. Or run `WSMDI-Discovery.ps1` / `WSMDI-Validate.ps1`. **How to implement if missing:** Onboard MDI

sensors using the catalog **Defender XDR Deployment / Unified Onboarding** solution before running the workshop. Sensor onboarding is out of scope here.

R2. A pilot/lab scope for the labs

Description: A defined **lab or pilot ring** — a small set of test users, a test domain controller environment, or a documented pilot slice of production — against which the labs are performed. **Why required:** The workshop is delivered pilot-first (per the deployment model). Honeytoken tagging and investigation practice should not target live privileged production identities on the first pass. **How to verify:** Confirm a named pilot group in Entra/Intune, or an isolated lab domain, exists and the facilitator has access to it. **How to implement if missing:** Create a pilot ring (see the global requirements) or stand up a small AD lab. A non-production lab is the safest venue for the honeytoken and response-rehearsal labs.

R3. ISPM assessment data populated

Description: Identity Security Posture Management assessments have run and produced recommendations. **Why required:** Lab 4 reads the ISPM recommendations. Assessments populate over time after the sensors report; an empty ISPM view has nothing to work. **How to verify:** In the portal, open **Secure Score** (or **Exposure management** → **Recommendations**) and filter to **Identity** recommendations; confirm items are listed. `WSMDI-Validate.ps1` reports whether posture data is present. **How to implement if missing:** Allow a warm-up window (typically hours to a few days) after sensor onboarding for assessments to populate. *Warm-up timing varies — verify in your tenant.*

R4. A candidate account for the honeytoken lab

Description: A **dormant, unused** directory account that can be designated the workshop honeytoken (created for the lab or an existing never-used account). **Why required:** A honeytoken must be an account that legitimately should **never** authenticate, so any activity is high-fidelity. Using an active account produces false positives. **How to verify:** Identify an account with no recent sign-ins. `WSMDI-Discovery.ps1` lists candidate low-/no-activity accounts (read-only) for the facilitator to choose from — it does **not** tag anything. **How to implement if missing:** Create a decoy account in the lab (e.g. `svc-legacy-backup` in `contoso.com`) with a strong password, no group memberships beyond default, and never sign in with it.

R5. Advanced hunting access (identity tables)

Description: Attendees can open **Advanced hunting** in the Defender portal and query the `Identity*` tables. **Why required:** Labs 2 and 5 run the KQL pack (`WSMDI-LabQueries.kql`) against `IdentityLogonEvents`, `IdentityQueryEvents`, `IdentityDirectoryEvents`, and `IdentityInfo`. **How to verify:** Open **Hunting** → **Advanced hunting**; run `IdentityInfo | take 5`; confirm rows return. **How to implement if missing:** Grant attendees a role that includes advanced-hunting read (e.g. **Security Reader** plus hunting permissions, or a Defender XDR custom role). *Confirm role mapping in your tenant.*

R6. Read-only Graph app or delegated permissions for the lab helpers

Description: The PowerShell lab helpers authenticate to Microsoft Graph with **read-only** security scopes. **Why required:** `WSMDI-Discovery.ps1`, `WSMDI-Validate.ps1`, and `WSMDI-Report.ps1` pull alerts,

secure-score, and account data for the labs. **How to verify:** Run `Connect-MgGraph -Scopes "SecurityAlert.Read.All","SecurityEvents.Read.All"` and confirm consent succeeds. `WSMDI-Validate.ps1` checks scope availability. **How to implement if missing:** Have a Global Administrator consent the delegated read scopes once, or register a read-only app registration for the workshop. Never grant write/response scopes for the labs.

R7. Facilitator with the right role, attendees with reader access

Description: One **facilitator** (Security Administrator) to drive configuration steps (honeytoken tag); **attendees** with **Security Reader** (plus hunting) to follow along read-only. **Why required:** Least privilege — only the facilitator needs the single configuration action (tagging the honeytoken); everyone else learns read-only and rehearses response in **simulate** mode. **How to verify:** Entra → **Roles and administrators**; confirm the facilitator holds Security Administrator and attendees hold Security Reader. **How to implement if missing:** Assign the roles before the session; keep response/write roles reserved for the approval-gated response rehearsal only.

Global Requirements — Defender (category-level)

These requirements apply to every solution in the Defender category (Microsoft Defender XDR and Defender for Cloud). Published once at the category level so listings stay small. Confirm before deploying any Defender solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *Defender changes touch detection and response for the whole tenant. Onboard in a ring (pilot devices/users first), keep automated response in an approval/simulate posture until trusted, and never disable an existing control to "test."*

G1. Microsoft 365 / Entra tenant

Description: An active Microsoft 365 tenant with Entra ID. Why: Defender XDR services and the unified portal (security.microsoft.com) are tenant workloads. Verify: Sign in to `https://security.microsoft.com` as an administrator. Implement: Provision a Microsoft 365 tenant and confirm Entra ID identities exist.

G2. Defender licensing

Description: The Defender plans for the pillars in scope — e.g. Defender for Endpoint P1/P2, Defender for Identity, Defender for Office 365 P1/P2, Defender for Cloud Apps, and Defender for Cloud plans. Why: Each pillar/feature is license-gated; onboarding without the plan fails or silently limits features. Verify: Admin center -> `Billing -> Licenses` (or the Defender portal). *Confirm the exact plan each feature needs — verify current availability in your tenant.* Implement: Assign the required plans (often bundled in M365 E5 / E5 Security) before onboarding.

G3. Administrative roles (least privilege)

Description: Security Administrator (and Global Administrator for first-time service activation). Why: Onboarding, RBAC, and policy changes in the Defender portal require these roles. Verify: Entra -> `Roles and administrators`; confirm Security Administrator. Implement: Assign Security Administrator; reserve Global Administrator for one-time activations.

G4. Onboarding reach to endpoints / identity / workloads

Description: A management channel to onboard the pillars — Intune/Configuration Manager/GPO/script for endpoints, domain controllers/AD FS for Identity sensors, and cloud connectors for Defender for Cloud. Why: Each pillar collects signal from a source that must be reachable and instrumented. Verify: Endpoints are managed (Intune/CM); DCs are reachable; cloud subscriptions are connected. Run the solution's discovery script. Implement: Establish the onboarding channel per pillar (see the relevant catalog endpoint/identity solutions).

G5. Network access to Defender service endpoints

Description: Outbound HTTPS to the Microsoft Defender / Microsoft 365 service URLs from onboarded assets. Why: Sensors and agents report to the cloud service; blocked endpoints break onboarding and detections. Verify: Confirm the documented Defender endpoint URLs/IP ranges are allowed. *Verify current endpoint list.* Implement: Allow the Defender/M365 endpoints through proxy/firewall.

G6. A pilot ring

Description: A defined set of pilot devices/users/subscriptions to onboard first. Why: XDR onboarding and automated response are validated on a ring before tenant-wide rollout. Verify: A pilot group exists in Entra/Intune. Implement: Create the pilot ring before enabling anything that acts automatically.

G7. Log Analytics workspace (where required)

Description: A Log Analytics workspace for Defender for Cloud / advanced hunting export where used. Why: Some Defender data and continuous export land in a workspace. Verify: A workspace exists and is access-controlled. Run the discovery script. Implement: Provision a workspace (or reuse the SIEM/observability one) with least-privilege access.

G8. Response governance

Description: An agreed position on automated response (auto-remediation levels, approval requirements). Why: XDR/AIR can take disruptive actions (isolate, delete, disable); the organization must decide the guardrails. Verify: A documented response policy exists; automation is in an approval/simulate posture until trusted. Implement: Define response guardrails; keep AIR/automation approval-gated at first. *Incident-response decisions are the SOC/security team's; this guide covers the technical configuration.*

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation — Workshop Runbook: Microsoft Defender for Identity

This is the **facilitator + student runbook**. Run the labs in order against the **pilot/lab** scope from R2. Every object you create uses a consistent naming convention `<Purpose> – <Scope> – <Stage>` and is reused by name in later labs, testing, and the scripts. All steps are **read-only or preview-first**; the one configuration action (tagging a honeytoken) and the response rehearsal are **facilitator-driven and**

approval-gated.

Naming convention used throughout

- Honeytoken account: `svc-legacy-backup` (in `contoso.com`) — tagged `Honeytoken – Identity Lab – Pilot`.
- Saved hunting queries: `Recon – Identity Lab – Pilot`, `LateralMovement – Identity Lab – Pilot`, `Honeytoken – Identity Lab – Pilot`.
- Investigation notebook / findings doc: `Investigation – Identity Lab – Pilot`.
- Remediation shortlist output: `ISPM-Shortlist – Identity Lab – Pilot`.

*Portal navigation paths reflect the current Microsoft Defender portal (`https://security.microsoft.com`). Microsoft moves menus periodically — *verify current navigation in your tenant*; the troubleshooting guide lists the moved-menu fallbacks.*

Lab 0 — Readiness check (Assess)

Goal: confirm the environment is ready before teaching.

1. Sign in to `https://security.microsoft.com` as the **facilitator** (Security Administrator).
2. Go to **Settings** → **Identities** → **Sensors**. Confirm at least one sensor shows **Healthy** (R1).
3. From the facilitator workstation, run the read-only discovery helper:

`powershell -ExecutionPolicy Bypass -File .\WSMDI-Discovery.ps1` Confirm it reports a healthy sensor, recent identity alerts (if any), and lists **candidate honeytoken accounts**.

1. Run `powershell -ExecutionPolicy Bypass -File .\WSMDI-Validate.ps1` and confirm the readiness checks (sensor health, ISPM data present, hunting access) pass.
2. **Pass gate:** discovery + validate both green; ISPM recommendations visible in **Secure Score**. If not, resolve using Requirements R1–R6 before continuing.

Lab 1 — Identity attack paths & the entity page (Configure/learn)

Goal: read an entity page and interpret investigation priority and lateral-movement paths.

1. In the portal, open **Assets** → **Identities** (or search a username in the global search).
2. Open a **user** entity page for a pilot account. Walk the panels together:

- **Overview** — investigation priority score, tags, and account risk.
- **Timeline** — authentications, alerts, and directory changes over time.
- **Observed in organization / Lateral movement paths** — how this identity could be used to reach higher-privilege accounts.

1. Open a **device** (domain controller) entity page; note logons observed and related identities.
2. Discuss: an **attack path** chains an exposed/compromised identity to a privileged one. Higher investigation priority = investigate first.

3. **Pass gate:** each attendee can, on a second entity page, correctly point to the timeline, the lateral-movement path panel, and the investigation-priority score, and explain what each means.

Lab 2 — Recon & lateral-movement detections (Pilot)

Goal: recognize the detection families, map them to MITRE ATT&CK, and triage an alert.

1. Open **Incidents & alerts** → **Alerts**. Filter **Service source = Defender for Identity**.

2. Review the detection families with the group (use real alerts if present, otherwise the descriptions in the runbook):

• **Reconnaissance** — account/SAMR enumeration, SPN reconnaissance (Kerberoasting recon), network mapping (Discovery, TA0007).

• **Compromised credentials** — brute force, password spray (Credential Access, TA0006).

• **Lateral movement** — Pass-the-Hash, Pass-the-Ticket, overpass-the-hash, remote code execution (Lateral Movement, TA0008).

• **Domain dominance** — DCSync, DCShadow, Golden Ticket, skeleton key (Credential Access / Persistence).

1. Open **Hunting** → **Advanced hunting**. Paste the **Recon** and **Lateral movement** sections of `WSMDI-LabQueries.kql`. Run them; review results.

2. Save the two queries as `Recon – Identity Lab – Pilot` and `LateralMovement – Identity Lab – Pilot` (**Save** → **Save as**).

3. Take one alert (or one query hit) through triage: what identity, what technique, is it expected, what would escalate it.

4. **Pass gate:** each attendee maps a chosen detection to its MITRE tactic and states the first two triage questions.

Lab 3 — Honeytokens (Pilot, one facilitator config action)

Goal: deploy and verify a honeytoken; understand its detection.

1. **Facilitator only:** choose the decoy account `svc-legacy-backup` (from R4 / the discovery output). Confirm it has **no legitimate sign-ins**.

2. Tag it: **Settings** → **Identities** → **Entity tags** → **Honeytoken** → **Add**; add `svc-legacy-backup`. (This is the single configuration change in the workshop.) Record it as `Honeytoken – Identity Lab – Pilot`.

3. Explain the model: a honeytoken should *never* authenticate, so **any** logon/query against it is high-fidelity. MDI raises **"Honeytoken activity"** when it is touched.

4. In **Advanced hunting**, paste the **Honeytoken** section of `WSMDI-LabQueries.kql` (filters identity events to the tagged account), run it, and **Save as** `Honeytoken – Identity Lab – Pilot`.

5. *(Optional, lab environment only)* From a test workstation, attempt a benign authentication as the honeytoken to generate the detection, then observe the alert. **Do not do this in production.**

6. **Pass gate:** the honeytoken is tagged and visible under Entity tags; the saved query returns the account; attendees can explain why any activity is a real signal.

Lab 4 — ISPM posture (Validate posture, no enforcement)

Goal: read and prioritize identity posture recommendations — produce a shortlist, not a change.

1. Open **Secure Score** (or **Exposure management** → **Recommendations**) and filter to **Identity** / **Defender for Identity** recommendations.

2. Walk the common recommendations: remove **unconstrained delegation**, disable **legacy/weak protocols**, address **exposed credentials**, review **dormant privileged accounts**, and **SAM-R / printer-spooler** hardening. Note each recommendation's impact and affected entities.

3. Run `powershell -ExecutionPolicy Bypass -File .\WSMDI-Report.ps1` to export a read-only posture summary.

4. As a group, build the `ISPM-Shortlist – Identity Lab – Pilot` — the top 3–5 recommendations ranked by impact and effort. Record owner candidates.

5. **Important boundary:** the workshop **does not enforce** any change. Actual remediation and change approval belong to the customer's security/ops functions and follow their change process.

6. **Pass gate:** a written shortlist exists and each attendee can explain why the top item ranks first.

Lab 5 — Investigation end-to-end + response rehearsal (Validate/Expand)

Goal: run a full identity investigation and rehearse response in a **simulate/approval-gated** posture.

1. Pick a lead: a real alert from Lab 2, the honeytoken hit from Lab 3, or a chosen entity from Lab 1.

2. Build the story on the **user entity page**: timeline → related alerts → lateral-movement path → involved devices. Cross-check in **Advanced hunting** with the saved queries.

3. Capture findings in the `Investigation – Identity Lab – Pilot` doc: what happened, which identities/devices, which technique, confidence, and recommended action.

4. **Response rehearsal (approval-gated):** from the entity page, review the available response actions — **Disable user**, **Force password reset**, **Suspend** — and discuss **when** each applies. In production, these require the organization's approval gate. **In the workshop, describe/queue the action for approval; do not execute against a production identity.** MDI also feeds XDR **automatic attack disruption** — discuss how that changes the playbook.

5. Discuss the hand-off to the SOC: the incident, the evidence, and who decides. **Incident-response and containment decisions are the SOC/security team's, not the workshop's.**

6. **Pass gate:** a completed investigation doc plus each attendee correctly stating which response action fits the scenario and who must approve it.

Wrap-up (Expand)

1. Confirm the take-home artifacts exist: the three saved hunting queries, the honeytoken tag, the ISPM shortlist, and the investigation doc.

2. Run the **knowledge-check** in `05-testing.md`.

3. Agree the **expand** plan: apply the runbook to full production scope through the customer's change process, and use this runbook to onboard new analysts.

5. Testing & Knowledge-Check — Workshop: Microsoft Defender for Identity

Testing a workshop means two things: (1) confirming each lab's **pass gate** was met, and (2) a **knowledge-check** that each attendee can operate MDI unaided. Use the lab-helper scripts by name to validate the environment; use the check-questions to validate the people.

Part A — Environment / lab validation (scripts)

A1. Readiness (before the workshop)

Run `WSMDI-Validate.ps1`. Expected: sensor health **Healthy**, ISPM/posture data present, advanced-hunting access confirmed, read scopes consented. All green = ready to teach.

A2. Discovery sanity

Run `WSMDI-Discovery.ps1`. Expected: at least one healthy sensor listed, recent identity alert count reported, and a list of **candidate honeytoken accounts**. Confirms the tenant has real telemetry to investigate.

A3. Honeytoken configured (after Lab 3)

In **Settings** → **Identities** → **Entity tags** → **Honeytoken**, confirm `svc-legacy-backup` is present. Run the saved query `Honeytoken – Identity Lab – Pilot` in advanced hunting and confirm it returns the account.

A4. Saved queries present (after Lab 2)

In **Advanced hunting** → **Queries**, confirm `Recon – Identity Lab – Pilot` and `LateralMovement – Identity Lab – Pilot` exist and run without syntax error.

A5. Posture report (after Lab 4)

Run `WSMDI-Report.ps1`; confirm it produces a posture summary and that the `ISPM-Shortlist – Identity Lab – Pilot` was captured.

Part B — Knowledge-check (per attendee)

Score each attendee; passing = correct on at least 8 of 10.

1. **Sensors:** Which servers host MDI sensors, and what does each observe? *(DCs, AD CS, AD FS/Entra Connect — authentication and directory traffic/behavior.)*

2. **Attack path:** On an entity page, where do you find lateral-movement paths and the investigation-priority score, and what do they mean?

3. **Detection families:** Name the four families and give one detection each *(recon, compromised credentials, lateral movement, domain dominance)*.

4. **MITRE:** Map Pass-the-Ticket and DCSync to their MITRE tactics *(Lateral Movement; Credential Access)*.

5. **Honeytoken:** What makes an account a good honeytoken, and why is any activity on it high-fidelity?

6. **Hunting:** Which advanced-hunting tables hold identity telemetry? *(IdentityLogonEvents, IdentityQueryEvents, IdentityDirectoryEvents, IdentityInfo.)*

7. **ISPM:** Give two ISPM recommendations and explain the risk each addresses.

8. **Investigation:** Outline the steps to investigate a suspicious identity from entity page to advanced hunting.

9. **Response & governance:** What are the MDI response actions, and **who** must approve them before execution?

10. **Boundary:** Which decisions in an identity incident belong to the SOC/security team rather than to the tool operator?

Part C — Live demonstration (capstone)

Each attendee, unaided, does the following on a **second** entity or alert:

- Opens the entity page and reads the timeline + lateral-movement path.
- Runs one saved hunting query and interprets a result.
- States the recommended response action and the approval required.

Overall pass criteria: every attendee meets Part B (≥8/10) and completes Part C. Environment checks A1–A5 all pass. Record results against the roster; anyone below threshold repeats the relevant lab.

6. Troubleshooting — Workshop: Microsoft Defender for Identity

Symptom → cause → fix for the common issues when running the workshop and its lab helpers. For category-level prerequisites (licensing, roles, network) see `global-requirements-defender.md`.

Sensor shows Unhealthy or no sensors listed

- **Symptom: Settings** → **Identities** → **Sensors** shows no sensor, or a sensor is **Unhealthy**; entity pages are empty.
- **Cause:** MDI sensors are not onboarded, the service account/credentials are wrong, or outbound access to the MDI service is blocked.
- **Fix:** This workshop assumes onboarding is done — use the **Defender XDR Deployment / Unified Onboarding** solution to install/repair sensors. Confirm outbound HTTPS to the MDI service endpoints (global requirement G5). Do not run the labs until at least one sensor is **Healthy** (R1).

Entity pages / advanced hunting return no identity data

• **Symptom:** `IdentityInfo | take 5` returns nothing; user entity pages have empty timelines.

• **Cause:** Sensors only just onboarded (warm-up), the `Identity*` tables are not yet populated, or the account lacks hunting permission.

• **Fix:** Allow a warm-up window after onboarding (*timing varies — verify in your tenant*). Confirm the attendee role includes advanced-hunting read (R5). Re-run `WSMDI-Validate.ps1`.

ISPM recommendations are empty (Lab 4)

• **Symptom:** Filtering Secure Score / Exposure management to **Identity** shows no recommendations.

• **Cause:** ISPM assessments have not populated yet, or you are looking at the wrong blade.

• **Fix:** Wait for assessments to run after sensor onboarding (R3). Try both **Secure Score** and **Exposure management** → **Recommendations**; menus move — *verify current navigation*. Confirm sensors are healthy first.

`Connect-MgGraph` fails or scopes are not granted

• **Symptom:** The lab scripts error on connect, or `WSMDI-Validate.ps1` reports fewer scopes than requested.

• **Cause:** The delegated read scopes were not consented, or the account lacks the directory role to consent.

• **Fix:** Have a Global Administrator consent the read scopes once (`SecurityAlert.Read.All`, `SecurityEvents.Read.All`, `AuditLog.Read.All`, `User.Read.All`), or register a read-only workshop app. Never grant write/response scopes for the labs (R6).

`Get-MgSecurityAlertV2` returns nothing

• **Symptom:** Discovery/report show 0 MDI alerts.

• **Cause:** A genuinely quiet tenant, alerts outside the query window, or the provider filter excluded them.

• **Fix:** A quiet tenant is fine for teaching — use the runbook descriptions and the honeytoken lab to generate signal in a **lab**. Widen the time range. Confirm Defender for Identity is licensed and active (global requirement G2).

`signInActivity` is blank (honeytoken candidate list empty)

• **Symptom:** `WSMDI-Discovery.ps1` / `WSMDI-Honeytoken-Lab.ps1` list no candidates or blank last-sign-in.

• **Cause:** `signInActivity` requires **Entra ID P1/P2** and `AuditLog.Read.All`; without them the property is empty.

• **Fix:** Confirm the Entra plan and the scope (*verify availability*). If unavailable, the facilitator picks a decoy account manually (create `svc-legacy-backup` in the lab) — the honeytoken does not depend on this list.

Honeytoken detection did not fire in the demo

• **Symptom:** After a benign lab sign-in as the honeytoken, no **"Honeytoken activity"** alert appears.

• **Cause:** The account was not correctly tagged, detection latency, or the auth path was not observed by a sensor.

• **Fix:** Confirm the tag under **Entity tags** → **Honeytoken**; allow detection latency; ensure the authentication traversed a monitored DC. Never test honeytokens in production — only in a lab.

Response actions greyed out (Lab 5)

• **Symptom: Disable user / Force password reset** are unavailable on the entity page.

• **Cause:** The attendee holds a read-only role (by design), or the action requires higher privilege / the approval gate.

• **Fix:** This is expected — attendees learn read-only and **rehearse** response. Only the facilitator (with the appropriate role) demonstrates the action, and only in a lab / with approval. Do not execute against a production identity during training.

Portal menu paths don't match

• **Symptom:** A navigation path in the runbook doesn't exist.

• **Cause:** Microsoft periodically relocates Defender portal menus.

• **Fix:** Use global search (top bar) for the feature name (e.g. "Honeytoken", "Entity tags", "ISPM"). *Verify current navigation in your tenant* and update your copy of the runbook.

7. Best Practices & Where to Go Next — Workshop: Microsoft Defender for Identity

Running the workshop well

• **Teach against a pilot/lab, not production privileged identities.** Do the honeytoken and response-rehearsal labs where a mistake is harmless. Expand to production only through the customer's change process.

• **Read-only by default.** The only configuration action is tagging the honeytoken (facilitator). Everything else is discovery, hunting, and reading — keep it that way so learning never disrupts detection.

• **Simulate before you enforce.** Response actions (disable, force reset) are rehearsed and queued for approval, never fired against a production identity during training.

• **Use consistent object names.** The `<Purpose> – <Scope> – <Stage>` convention (e.g. `Honeytoken – Identity Lab – Pilot`) makes the take-home artifacts findable and reusable. Keep it.

• **Save the artifacts.** The three hunting queries, the honeytoken tag, the ISPM shortlist, and the investigation doc are the take-home runbook — make sure every attendee leaves with them.

Operating MDI well (the habits to instill)

• **Work the entity page first.** Investigation priority + timeline + lateral-movement path answers most triage questions before you open advanced hunting.

• **Treat honeytoken activity as real until disproven.** It is one of the highest-fidelity signals MDI produces — never suppress it.

• **Keep ISPM moving.** Posture recommendations drift as the directory changes; review them on a cadence and track a shortlist rather than trying to fix everything at once.

• **Hunt with saved queries.** Building a small library of saved identity queries (recon, lateral movement, honeytoken) turns ad-hoc investigation into a repeatable practice.

• **Respect the approval gate.** Disruptive response is a security-team decision. The operator's job is a clean, evidenced hand-off — not a unilateral action.

• **Mind licensing and preview.** Some detections/features are license- or preview-gated; confirm what your plan includes and *verify current availability in your tenant* before you promise a capability.

Common anti-patterns to avoid

• Turning the workshop into an onboarding project (that is a separate solution — keep this one about *operating*).

• Using an active account as a honeytoken (false positives destroy trust in the signal).

• Enforcing ISPM changes mid-workshop without change approval.

• Executing a response action against a production identity "to see what happens."

Where to go next (adjacent catalog areas)

• **Defender XDR Deployment / Unified Onboarding** — if sensors are not yet fully deployed, or to extend onboarding across endpoint/identity/cloud pillars.

• **Threat Hunting** — go deeper on cross-pillar hunting with KQL beyond the identity tables.

• **SOC / XDR operations** — incident queue management, automation, and SOC process design that consume MDI alerts.

• **Sibling Defender workshops** — Endpoint, Office 365, and Cloud Apps enablement workshops to round out the SOC's operating skills across the whole Defender suite.

• **Defender for Cloud CSPM / Secure Score** — posture management for cloud workloads, complementary to identity posture.

The bottom line: a team that operates MDI with confidence — reading attack paths, recognizing detections, deploying honeytokens, working posture, and running clean, approval-gated investigations — using a runbook they keep and reuse.

8. Deliverables Summary — Workshop: Microsoft Defender for Identity

This workshop is delivered as a **Complete Solution Package (PDF + Word + scripts)** — the documentation set below plus five lab-helper assets, yours to keep and reuse to train new analysts.

Documentation (source/)

• **executive-summary.md** — what the workshop is, the outcome, the boundary, and the effort.

• **01-solution-overview.md** — what MDI is, how sensors and identity detections work, the operator console/workflows, the five labs, and what is in/out of scope.

• **02-requirements.md** — workshop-specific prerequisites (healthy sensor, pilot scope, ISPM data, honeytoken candidate, hunting access, read scopes, roles), each with verify / implement-if-missing. Category-level prerequisites are in `global-requirements-defender.md`.

• **03-implementation.md** — the facilitator + student runbook: Lab 0 readiness plus the five guided labs, with named objects and pass/fail gates.

• **05-testing.md** — environment validation, the per-attendee knowledge-check, and the capstone demonstration.

• **06-troubleshooting.md** — symptom → cause → fix for the common workshop and MDI issues.

• **07-best-practices.md** — how to run the workshop and operate MDI well, plus where to go next in the catalog.

• **08-deliverables-summary.md** — this file.

• **global-requirements-defender.md** — the category-level prerequisites (shared across all Defender solutions).

Lab-helper assets (scripts/)

• **WSMDI-Discovery.ps1** — read-only discovery (Microsoft Graph Security): MDI sensor health, recent identity alerts, and candidate honeytoken accounts for Lab 0/Lab 3. Makes no changes.

• **WSMDI-Validate.ps1** — read-only readiness validation: sensor health, ISPM/posture data present, advanced-hunting access, and read-scope consent. Green = ready to teach.

• **WSMDI-Report.ps1** — read-only workshop/posture summary report: identity alert counts by severity and the ISPM recommendation list for the Lab 4 shortlist.

• **WSMDI-LabQueries.kql** — advanced-hunting KQL pack for Labs 2, 3, and 5: recon, lateral-movement, honeytoken-activity, and investigation queries over the `Identity*` tables.

• **WSMDI-Honeytoken-Lab.ps1** — read-only helper that lists dormant/no-sign-in candidate accounts and prints the exact portal steps to tag one as a honeytoken (**preview only — tags nothing**).

Take-home runbook artifacts (produced during the labs)

• Saved hunting queries: `Recon – Identity Lab – Pilot`, `LateralMovement – Identity Lab – Pilot`, `Honeytoken – Identity Lab – Pilot`.

• The honeytoken tag `Honeytoken – Identity Lab – Pilot` (`svc-legacy-backup`).

• The `ISPM-Shortlist – Identity Lab – Pilot` remediation shortlist.

• The `Investigation – Identity Lab – Pilot` findings document.

Delivered as a Word document and PDF, plus all five lab-helper scripts in a single ZIP — yours to keep and reuse.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

WSMDI-Discovery.ps1

Purpose: Read-only environment discovery for the "Workshop — Microsoft Defender for Identity" enablement package. Confirms the tenant has identity telemetry to teach against: recent Defender for Identity alerts (via Microsoft Graph Security), a summary by severity, and a list of dormant / no-recent-sign-in accounts that are candidate honeytokens for Lab 3. Makes NO changes and tags nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\WSMDI-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\WSMDI-Discovery.ps1 -DormantDays 90 -OutputPath .\wsmdi-discovery.json Requires the Microsoft.Graph modules. The script connects with READ-ONLY delegated scopes; consent as a Security Reader / Security Administrator when prompted. EXPECTED RESULTS A console summary plus a JSON file: MDI alert count by severity, the most recent alerts, and candidate honeytoken accounts (no sign-in within -DormantDays). Use it in Lab 0 (readiness) and to pick the honeytoken in Lab 3. .NOTES White-label. Read-only. Reports configuration/identifiers only; makes no changes. Feature/licensing facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param([int]$DormantDays = 90, [string]$OutputPath = ".\wsmdi-discovery.json")

How to run: powershell -ExecutionPolicy Bypass -File .\WSMDI-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\WSMDI-Discovery.ps1 -DormantDays 90 -OutputPath .\wsmdi-discovery.json Requires the Microsoft.Graph modules. The script connects with READ-ONLY delegated scopes; consent as a Security Reader / Security Administrator when prompted. EXPECTED RESULTS A console summary plus a JSON file: MDI alert count by severity, the most recent alerts, and candidate honeytoken accounts (no sign-in within -DormantDays). Use it in Lab 0 (readiness) and to pick the honeytoken in Lab 3. .NOTES White-label. Read-only. Reports configuration/identifiers only; makes no changes. Feature/licensing facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param([int]$DormantDays = 90, [string]$OutputPath = ".\wsmdi-discovery.json")

WSMDI-Honeytoken-Lab.ps1

Purpose: Supports Lab 3 of the "Workshop — Microsoft Defender for Identity". It (1) lists dormant / no-recent-sign-in accounts that are safe honeytoken candidates, and (2) prints the precise, current portal navigation to TAG the chosen account as a honeytoken. Tagging is a deliberate facilitator action done in the portal — this script does NOT perform it (no write scope is requested), keeping the workshop read-only/preview-first. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\WSMDI-Honeytoken-Lab.ps1 powershell -ExecutionPolicy Bypass -File .\WSMDI-Honeytoken-Lab.ps1 -DormantDays 120 Run as Security Reader / Security Administrator; consent the read-only scopes when prompted. EXPECTED RESULTS A shortlist of candidate accounts and a printed step-by-step for the portal honeytoken tag. The facilitator picks one candidate (e.g. svc-legacy-backup) and tags it in the portal. .NOTES White-label. Read-only / preview-first. Requests NO write scopes and changes nothing. A honeytoken must be an account that should NEVER legitimately authenticate. > [CmdletBinding()] param([int]$DormantDays = 90)

How to run: powershell -ExecutionPolicy Bypass -File .\WSMDI-Honeytoken-Lab.ps1 powershell -ExecutionPolicy Bypass -File .\WSMDI-Honeytoken-Lab.ps1 -DormantDays 120 Run as Security Reader / Security Administrator; consent the read-only scopes when prompted. EXPECTED RESULTS A shortlist of candidate accounts and a printed step-by-step for the portal honeytoken tag. The facilitator picks one

candidate (e.g. svc-legacy-backup) and tags it in the portal. .NOTES White-label. Read-only / preview-first. Requests NO write scopes and changes nothing. A honeytoken must be an account that should NEVER legitimately authenticate. > [CmdletBinding()] param([int]$DormantDays = 90)

WSMDI-LabQueries.kql

WSMDI-Report.ps1

Purpose: Produces a compact, read-only summary the facilitator can share at the end of the Defender for Identity workshop: a count of Defender-for-Identity alerts by severity/status, the most recent alerts, and a template for the "ISPM-Shortlist - Identity Lab - Pilot" (the top recommendations to remediate later, captured in the portal during Lab 4). Makes NO changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\WSMDI-Report.ps1 powershell -ExecutionPolicy Bypass -File .\WSMDI-Report.ps1 -OutputPath .\wsmdi-report.html Run as Security Reader / Security Administrator; consent read-only scopes when prompted. EXPECTED RESULTS A console summary and an HTML report file. The ISPM section is a fill-in template because the prioritized recommendation list is authored in the portal (the choice of what to remediate, and change approval, belong to the customer's security/ops functions). .NOTES White-label. Read-only. Makes no changes. Licensing/preview facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param([string]$OutputPath = ".\wsmdi-report.html")

How to run: powershell -ExecutionPolicy Bypass -File .\WSMDI-Report.ps1 powershell -ExecutionPolicy Bypass -File .\WSMDI-Report.ps1 -OutputPath .\wsmdi-report.html Run as Security Reader / Security Administrator; consent read-only scopes when prompted. EXPECTED RESULTS A console summary and an HTML report file. The ISPM section is a fill-in template because the prioritized recommendation list is authored in the portal (the choice of what to remediate, and change approval, belong to the customer's security/ops functions). .NOTES White-label. Read-only. Makes no changes. Licensing/preview facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param([string]$OutputPath = ".\wsmdi-report.html")

WSMDI-Validate.ps1

Purpose: Confirms the environment is ready to teach the "Workshop — Microsoft Defender for Identity" labs BEFORE attendees arrive. Checks (all read-only): Microsoft Graph connectivity and the required READ scopes are consented, that Defender-for-Identity alert data is reachable, and that identity posture (ISPM) signal is present. Prints a green/red readiness table. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\WSMDI-Validate.ps1 Run as a Security Reader / Security Administrator; consent the read-only scopes when prompted. EXPECTED RESULTS A PASS/REVIEW line per check. All PASS = ready to run Lab 0 onward. Any REVIEW points at the matching item in 02-requirements.md. .NOTES White-label. Read-only. Makes no changes. Licensing/preview facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param()

How to run: powershell -ExecutionPolicy Bypass -File .\WSMDI-Validate.ps1 Run as a Security Reader / Security Administrator; consent the read-only scopes when prompted. EXPECTED RESULTS A PASS/REVIEW line per check. All PASS = ready to run Lab 0 onward. Any REVIEW points at the matching item in 02-requirements.md. .NOTES White-label. Read-only. Makes no changes. Licensing/preview facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param()